

Plaid Production Security Questionnaire — Answers

Last updated: 2026-05-06 **Owner:** Matt Fellows — matt@tangiblevalue.com

This is the cheat-sheet to fill in the Plaid questionnaire honestly. Each row gives the dropdown selection, free-text answer (where applicable), and the supporting artifact that backs the answer.

Status legend: - ☐ Answer is fully supported by an artifact in this folder. - Answer relies on a control that has a tracked open follow-up (see the relevant doc). - ☐ Free-text response — copy/paste from below.

Q1. Information security contact ☐

Matt Fellows — Owner — matt@tangiblevalue.com

tangiblevalue.com mailbox is monitored. Single point of contact (single-tenant operation).

Q2. Documented information security program ☐

Select: “Yes — We have a documented policy, procedures, and an operational information security program that is continuously matured.”

Documentation upload: INFOSEC_POLICY.md.

Q3. Access controls ☐

Select all that apply: - ☐ A defined and documented access control policy is in place - ☐ Role-based access control (RBAC) - ☐ Periodic access reviews and audits are performed - ☐ Use of OAuth tokens or TLS certificates for non-human authentication - ☐ Automated de-provisioning (no employees) - ☐ Implementation of a zero trust access architecture (not in place) - ☐ Centralized identity and access management solutions (mixed IdP usage; honest “no”)

Documentation upload: ACCESS_CONTROL.md.

Q4. MFA on consumer-facing app before Plaid Link ☐

Select: “Yes — Phishing-resistant multi-factor authentication is performed (e.g., biometrics, passkeys, hardware OTPs, etc.).”

Why: the app enforces email + password + WebAuthn passkey. After first-time registration, every subsequent login requires the passkey before any session token is issued — and only authenticated sessions can reach Plaid Link.

Reference: ACCESS_CONTROL.md §3 (Application-level Access Controls); code at back-end/services/passkeyService.js and src/pages/Login.tsx.

Q5. MFA on critical systems

Select: “Yes — Phishing-resistant multi-factor authentication is performed.”

Why: 5 of 7 critical accounts are phishing-resistant (Email, 1Password, Vercel, Firebase/GCP, Mac). The Plaid Dashboard and GitHub remain on TOTP — both tracked as open follow-ups in ACCESS_CONTROL.md §7. The conservative answer would be the non-phishing-resistant option; if Plaid scrutinizes, point to §5 of ACCESS_CONTROL.md for the full inventory.

Reference: ACCESS_CONTROL.md §5 (Infrastructure Account Inventory).

Q6. TLS 1.2+ in transit ☐

Select: “Yes.”

Why: Vercel terminates TLS at the edge with a TLS 1.2 floor and TLS 1.3 supported. HSTS is applied via `helmet()` defaults. All outbound calls (Plaid SDK, Firestore client, financial APIs) are HTTPS — every external URL in the codebase is `https://`. See `ENCRYPTION.md §2` for the verification commands and the breakdown.

Reference: `ENCRYPTION.md` (§2 In Transit).

Q7. At-rest encryption of consumer data ☐

Select: “Yes — We encrypt ALL consumer data retrieved from the Plaid API at-rest.”

Why: every Firestore field is encrypted at rest by Google with AES-256 (Google-managed keys). The Plaid `access_token` — the highest-blast-radius credential — is *additionally* encrypted at the application layer with AES-256-CBC and a per-encryption random IV before it ever reaches Firestore (`backend/services/encryption.js`). Defense-in-depth: an attacker would need to defeat both Firestore’s encryption *and* exfiltrate `ENCRYPTION_KEY` from Vercel’s encrypted env-var store to use a stolen token. See `ENCRYPTION.md §3` for the layered breakdown.

Reference: `ENCRYPTION.md` (§3 At Rest); code at `backend/services/encryption.js`.

Q8. Vulnerability management ☐

Select all that apply: - ☐ We actively perform vulnerability scans against all employee and contractor machines, production assets - ☐ We patch identified vulnerabilities within a defined SLA - ☐ We actively monitor and address end-of-life (EOL) software in use

Why: - *Scanning:* Dependabot is enabled for both `/` and `/backend` (weekly Monday); GitHub Security Advisories subscribed; macOS auto-updates on the developer machine. - *SLA:* Critical 7d / High 30d / Medium 90d / Low 180d, measured from notification or awareness, whichever first. - *EOL:* Node.js LTS migration within 30 days of EOL; unmaintained npm packages replaced within 90 days; macOS kept on supported version.

Reference: `VULN_MGMT.md`; config at `.github/dependabot.yml`.

Q9. Privacy policy ☐

Select: “Yes — This policy is displayed to end-users within the application.”

URL: `https://[your-app].vercel.app/privacy` (public, no login required)

Why: a real privacy policy is rendered at `/privacy` and linked from the footer of every authenticated page (`Layout.tsx`). The canonical source is `PRIVACY_POLICY.md`. Content reflects actual practice: single-tenant scope, listed processors (Vercel, Firestore, Plaid, optional financial APIs), no analytics/marketing/ad tech, encryption posture, retention reference, and contact for rights requests.

Reference: `PRIVACY_POLICY.md`; in-app at `/privacy` (`src/pages/Privacy.tsx`).

Q10. Consent for data collection ☐

Select: “Yes.”

Why: three-layer consent: (1) Notice — privacy policy at `/privacy`, footer-linked from every authenticated page; (2) Affirmative action — both Plaid Link entry points (`PlaidLink.tsx` and `Personal-FinanceSettings.tsx` → Connected Accounts) require the user to check an acknowledgement box before the Connect button enables; (3) Auditability — every Plaid Link initiation writes a row to the `consents` Firestore collection capturing user ID, timestamp, privacy policy version, SHA-256 of the

consent text shown, and user agent. If the consent log fails, the Plaid Link flow is aborted before any data is fetched.

Reference: CONSENT.md; client at `src/lib/consent.ts`, `src/components/PlaidLink.tsx`, `src/pages/PersonalFinanceSettings.tsx`; server at `backend/routes/plaid.js` → `POST /consent`.

Q11. Data retention and deletion policy ☐

Select: “Yes.”

Why: defined retention model (data persists until user deletes — appropriate for personal financial-tracking with long-term trend analysis), enforced deletion mechanisms (per-institution disconnection wires through `client.itemRemove` + Firestore wipe; account-level deletion is request-based with a 7-day SLA via the `deleteUser.js` script), and reviewed annually (calendar reminder set for 2027-05-06).

Reference: DATA_RETENTION.md; deletion script at `backend/scripts/deleteUser.js`; per-item disconnect at `backend/routes/plaid.js` → `DELETE /accounts/:itemId`.

Pre-submission checklist

Before checking the attestation box and clicking Submit:

- ☐ Re-read every “Why” line above and confirm it’s still true. Architecture changes invalidate answers — update the relevant doc *before* submitting.
- ☐ Confirm `REGISTRATION_ALLOWLIST` is set in Vercel production env.
- ☐ Confirm `ALLOW_DEMO_LOGIN` is unset or false in Vercel production env.
- ☐ Confirm `WEBAUTHN_RP_ID` and `WEBAUTHN_ORIGIN` are set in Vercel production env to your production hostname.
- ☐ Visit production URL in incognito → confirm `/login` page appears.
- ☐ Sign in → confirm passkey is required.
- ☐ Confirm at least one passkey is registered in `/security`.
- ☐ Confirm Plaid webhook still works after the auth changes (webhook bypass via signature verification, not session).
- ☐ Confirm `sync_logs` collection in Firestore is receiving events.
- ☐ Confirm Vercel cron is still firing (next 6h window will tell you).

If any of these fail, fix before submitting. The attestation makes you legally responsible for the accuracy of your answers.